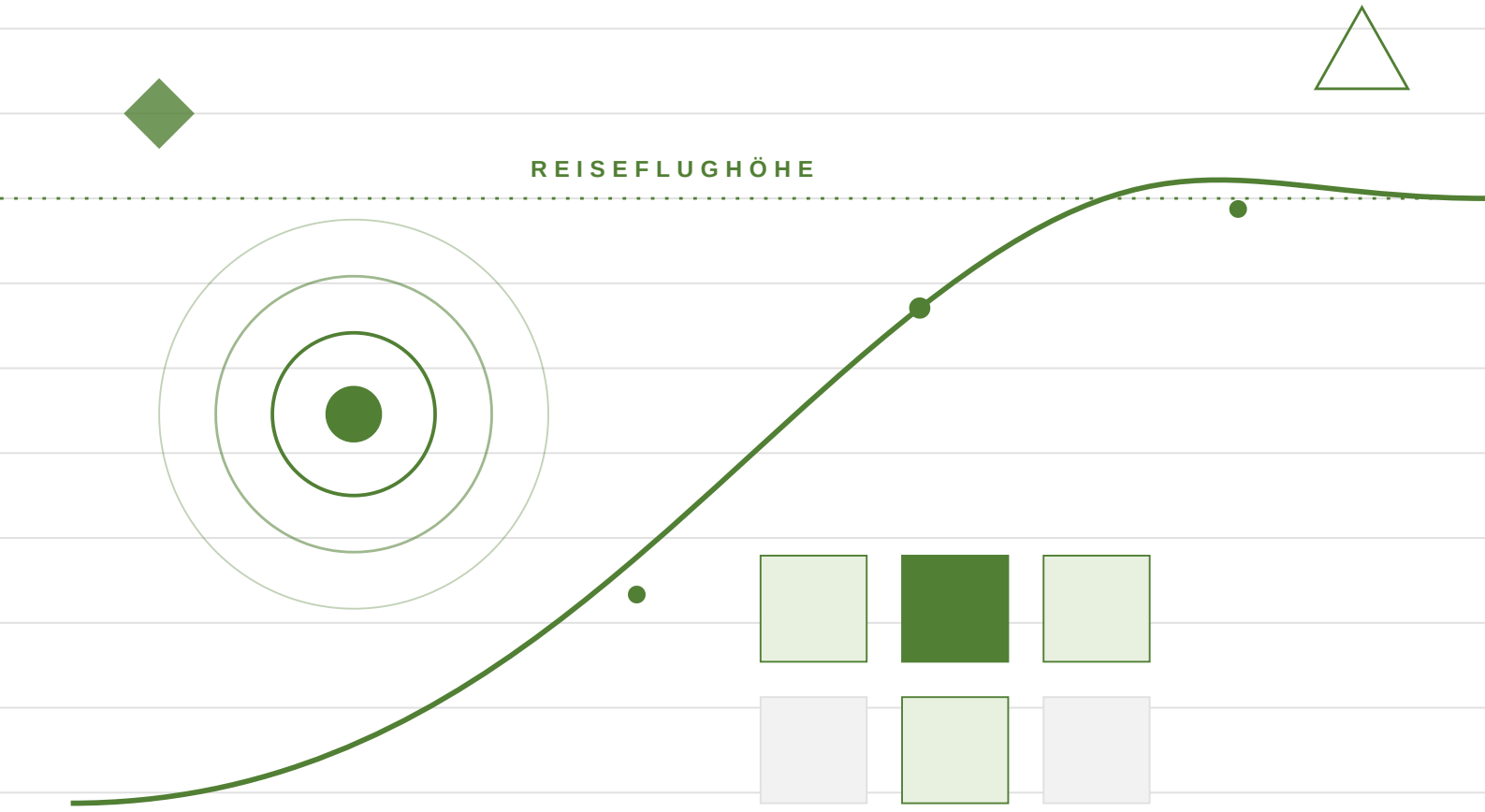


CYBERSICHERHEIT · KI-GOVERNANCE · DATENSCHUTZ · RESILIENZ

Security & Compliance

Widerstandsfähigkeit ist eine unternehmerische Fähigkeit. Wie widerstandsfähig ist Ihr Unternehmen wirklich?

ÜBERREICHT DURCH

Andreas Hagl

Wirkungsarchitekt im Alchimedus® consulting network

Telefon 0170/4792475

andreas.hagl@beratung-hagl.de

AUF EINEN BLICK

Sicherheit schützt den Fortbestand des Unternehmens

Sicherheit schützt nicht nur Daten. Sie schützt Lieferfähigkeit, Vertrauen, Entscheidungsfreiheit und den Fortbestand des Unternehmens.

01	02	03	04
Cybersicherheit	**KI-Governance**	**Datenschutz**	**Organisatorische Resilienz**

> Vier Themen, ein Ziel: Handlungsfähigkeit.

KAPITEL 1

Was wäre, wenn morgen früh nichts mehr funktioniert?

Montag, 7:42 Uhr

Das Warenwirtschaftssystem ist nicht erreichbar, der Vertrieb kann keine Aufträge öffnen, der IT-Dienstleister hat keinen Zugriff mehr. Dann die Nachricht: Daten kopiert, Systeme verschlüsselt.

> Wie lange bleibt Ihr Unternehmen handlungsfähig, wenn seine digitalen Selbstverständlichkeiten ausfallen?

Fiktives Szenario. Der Schaden entsteht entlang der gesamten Wertschöpfung: Entscheidungen werden vertagt, Kunden verlieren Vertrauen, Lieferzusagen geraten in Gefahr.

KAPITEL 2

Der zweite Vorfall: KI ohne Leitplanken

Gedankenexperiment

Ein Mitarbeiter hat vertrauliche Kundenlisten und Kalkulationen in ein frei verfügbares KI-Werkzeug kopiert. Ein anderer Bereich nutzt KI-generierte Vertragsformulierungen ohne fachliche Prüfung.

Sicherheit, Datenschutz und KI-Governance gehören zusammen. Produktive KI-Nutzung braucht klare Zuständigkeiten, sichere Datenwege und menschliche Kontrolle.

Die wichtigsten Vermögenswerte

01	02	03	04
Wissen	**Beziehungen**	**Reputation**	**Betriebsfähigkeit**

KAPITEL 3

Warum Sicherheit Chefsache ist

Betriebsfähigkeit
Laufen Aufträge, Zahlungen und Leistungen weiter?

Vertraulichkeit
Bleiben Kunden- und Unternehmensdaten geschützt?

Integrität
Sind Zahlen, Dokumente und KI-Ergebnisse zuverlässig?

Verantwortung
Sind Entscheidungen, Meldewege und Nachweise geregelt?

> Die Geschäftsführung muss nicht jede Firewall konfigurieren. Sie muss aber festlegen, welche Risiken tragbar sind.

HANDLUNGSFELD 1

Cybersicherheit beginnt mit Transparenz

- ☐ Welche Systeme sind unverzichtbar?
- ☐ Wer hat Zugriff?
- ☐ Welche Abhängigkeiten bestehen zu Dienstleistern und Cloud-Plattformen?

01
Mehrfaktor-Authentifizierung
für kritische Zugänge

02
Backups
Wiederherstellung regelmäßig testen

03
Updates und Rechte
verbindlich organisieren

04
Melden und eskalieren
Verdächtiges dokumentieren und schnell weitergeben

Technische Prüfungen und Umsetzung erfolgen durch qualifizierte Fachpartner.

HANDLUNGSFELD 2

KI-Governance: Regeln, die Nutzung ermöglichen

01 KI-Anwendungen und ihren Zweck erfassen

02 Verantwortliche für Freigabe, Nutzung und Überwachung benennen

03 Vertrauliche Daten und zulässige Eingaben klar regeln

04 Qualität, Fehler und menschliche Kontrolle risikogerecht gestalten

05 Mitarbeiter schulen, neue Anwendungsfälle regelmäßig bewerten

Rechtlicher Rahmen

Die EU-KI-Verordnung ist kein pauschales Verbot. Welche Pflichten greifen, hängt von Rolle, Einsatzart und Risiko ab und ist im Einzelfall zu prüfen.

HANDLUNGSFELD 3

Datenschutz: Datenflüsse verstehen

Datenschutz ist keine reine Dokumentationsaufgabe. Es geht darum, personenbezogene Daten rechtmäßig, zweckgebunden und geschützt zu verarbeiten.

Zwecke
Welche Daten werden wofür verarbeitet?

Dienstleister
Wer erhält Zugriff, welche Vereinbarungen sind nötig?

Löschung und Auskunft
Wann wird gelöscht, wer gibt Auskunft?

Fehlerfolgen
Was folgt aus einer Fehlversendung oder unzulässigen KI-Eingabe?

HANDLUNGSFELD 4

Organisatorische Resilienz

Widerstandsfähig ist, wer kritische Leistungen bei Störungen geordnet fortführen und wiederherstellen kann.

- ☐ Kennen wir die maximal tolerierbare Ausfallzeit unserer wichtigsten Prozesse?
- ☐ Gibt es Ersatzverfahren für Auftragseingang, Kundenkontakt und Zahlungen?
- ☐ Sind Vertretungen, Schlüsselwissen und Krisenkontakte verfügbar?
- ☐ Haben wir einen Wiederanlauf tatsächlich geübt?

> Ein schlanker, geübter Notfallplan ist wertvoller als ein umfangreiches Dokument, das im Ernstfall niemand findet.

HANDLUNGSFELD 5

Führung und Verantwortung

Sicherheit scheitert selten an fehlender Technik, sondern an Prioritäten, Zuständigkeiten und einer Kultur, in der Probleme zu spät angesprochen werden.

01

Geschäftsführung

definiert Risikobereitschaft und kritische Prozesse

02

Fachbereiche

verantworten ihre Daten und Abläufe

03

IT und Datenschutz

arbeiten zusammen, bei Bedarf mit externen Fachleuten

04

Vorfälle

werden ohne Schuldzuweisung gemeldet und ausgewertet

Aus dem Cockpit: Just Culture

In der Luftfahrt werden Fehler offen gemeldet, damit alle daraus lernen. Dieselbe Kultur macht Sicherheit im Unternehmen wirksam.

READINESS-CHECK

Der Security & Compliance Readiness-Check

30 Aussagen in fünf Feldern, bewertet von 1 (nicht vorhanden) bis 10 (etabliert und fortlaufend verbessert):

- Cybersicherheit
- KI-Governance
- Datenschutz
- Organisatorische Resilienz
- Führung und Verantwortung

Nicht der Durchschnitt entscheidet

Ein guter Gesamtwert kann einen gefährlichen Einzelmangel verdecken. Fehlende Backups oder unkontrollierte Zugriffe werden deshalb separat als kritisch markiert.

Orientierung für Managemententscheidungen — keine Zertifizierung, Rechtsberatung oder technische Sicherheitsprüfung.

MASSNAHMENPLAN

Vom Risikoprofil zum Maßnahmenplan

Priorisiert wird nach Schadenspotenzial, Eintrittswahrscheinlichkeit, betroffenen Prozessen, Aufwand und rechtlicher Dringlichkeit.

Sofort

Zugänge absichern, Backups testen, Datenabflüsse stoppen

Kurzfristig

Verantwortlichkeiten, KI-Regeln und Vorfallabläufe festlegen

Mittelfristig

Abläufe üben, Dienstleister bewerten, Schulungen etablieren

180 TAGE

In 180 Tagen zu mehr Handlungsfähigkeit

Tag 1–30	Verstehen und absichern: kritische Prozesse, Zuständigkeiten, KI-Nutzung sichtbar machen
Tag 31–60	Regeln etablieren: Zugriffe, Datennutzung, Notfallkommunikation, Schulungen
Tag 61–90	Wirksamkeit nachweisen: Wiederherstellung testen, Krisenfall durchspielen
Tag 91–120	Dienstleister bewerten: IT-, Cloud- und KI-Anbieter, Verträge, Ausweichlösungen
Tag 121–150	Routinen verankern: Berechtigungen prüfen, neue KI-Anwendungen vorab bewerten
Tag 151–180	Überprüfen: zweite Krisenübung, Check wiederholen, Prioritäten für zwölf Monate

FAZIT

Compliance schützt Handlungsfreiheit

> Compliance ist kein Selbstzweck. Der Einstieg ist die Frage, welche Fähigkeiten Ihr Unternehmen noch besitzt, wenn etwas schiefgeht.

IHR WEG

In zwei Stufen zur Wirkung

01

Konzept

Standortbestimmung, Risikoprofil, KI-Regeln und Notfallvorsorge. Förderfähig über BAFA.

02

Umsetzung

Einführung im Unternehmen. Förderfähig über INQA.

Technische Umsetzung und rechtliche Prüfung erfolgen durch Partner; Rechtsberatung ist nicht Teil der Leistung. Pflichten aus DSGVO, EU AI Act und gegebenenfalls NIS2 hängen von Größe, Tätigkeit und Anwendungsfall ab und sind gesondert zu prüfen.

IHR ANSPRECHPARTNER

Andreas Hagl

Wirkungsarchitekt im Alchimedus® consulting network

Strategieberater für kleine und mittlere Unternehmen, Wirkungs-Architekt und systemischer Organisationsentwickler. Er verbindet Unternehmensberatung mit den Prinzipien der Luftfahrt: Struktur, Führung und regelbasiertes Arbeiten.

TELEFON	0170/4792475
E-MAIL	andreas.hagl@beratung-hagl.de
WEB	www.andreas-hagl.de
ADRESSE	Schulstr. 15, 84104 Rudelzhausen

Das Alchimedus® consulting network verbindet unabhängige Wirkungsarchitekten, die Unternehmer des Mittelstands in Strategieentwicklung, Business Development und Compliance begleiten — ganzheitlich, methodisch fundiert und mit dem Blick auf langfristigen Erfolg.

Wie widerstandsfähig ist Ihr Unternehmen?

Der Security & Compliance Readiness-Check zeigt es: 30 Aussagen, fünf Felder, ein klares Risikoprofil.

Readiness-Check anfragen